

1. How would you evaluate the security posture of a Windows system after identifying multiple open services?

Answer: I would evaluate the Windows system by creating an inventory of all open ports and services, identifying which services are required, and determining whether they are exposed only to trusted networks or broader networks. I would identify service versions and compare them with known security advisories and patch levels. I would also review authentication controls, encryption, firewall rules, service privileges, and configurations. Finally, I would rank findings based on likelihood and impact, giving higher priority to remotely accessible services with known exploitable weaknesses.

2. Which factors would you consider when choosing a hacking tool for Windows vulnerability assessment, and why?

Answer: I would consider the tool's accuracy, reliability, compatibility with the Windows version, ability to identify service versions and vulnerabilities, reporting quality, update frequency, and support for safe authenticated or unauthenticated assessment. I would also consider the assessment scope and the possibility of disruption caused by active scanning. Tools should be selected according to the testing objective and authorized scope.

3. How would you evaluate the security risk associated with an exposed RPC service?

Answer: I would determine whether RPC is exposed beyond trusted networks, identify the RPC-related services and endpoints, and verify patch status and configuration. I would assess whether the service permits unauthenticated access, exposes sensitive information, or has known vulnerabilities. I would then evaluate exploitability, required privileges, network reachability, and potential impact such as remote code execution or information disclosure.

4. Why are Windows Null Sessions considered a security weakness, and how would you assess their impact?

Answer: Windows Null Sessions can allow unauthenticated users to obtain certain information when legacy configurations permit it. I would test, within authorization, whether anonymous access is enabled and what information can be enumerated, such as shares or account-related details. The impact depends on the information exposed and whether it supports further attacks. Unnecessary anonymous access should be disabled and current Windows security policies applied.

5. A Windows shared folder allows unauthorized users to access sensitive files. How would you evaluate the severity of this vulnerability?

Answer: I would verify exactly which files are accessible, identify the users or groups that can access them, and determine whether access is read-only or allows modification or deletion. I would classify the sensitivity of the data and determine possible privacy, financial, operational, or regulatory consequences. Exposure of confidential data to unauthorized users would generally be medium or high severity depending on the data and scope.

6. How would you distinguish between a vulnerable Windows service and a misconfigured Windows service during security testing?

Answer: A vulnerable service has an inherent security flaw, such as a known software vulnerability, while a misconfigured service may be secure by design but operated with unsafe settings, excessive privileges, weak authentication, or unnecessary network access. I would compare the service version with vendor advisories, inspect its configuration, reproduce the issue safely, and determine whether remediation requires patching or configuration changes.

7. How would you evaluate the effectiveness of information-gathering techniques against a Windows target?

Answer: I would evaluate whether information-gathering techniques identify the target's operating system, IP addresses, open ports, service versions, hostnames, shares, accounts, and other authorized metadata. Effectiveness should be measured by the relevance and accuracy of the information obtained and how much it helps identify attack paths or defensive gaps. False positives should also be documented.

8. If a Windows vulnerability can be exploited but requires local access, how would you classify its security impact compared with a remotely exploitable vulnerability?

Answer: A vulnerability requiring local access generally has a narrower initial attack surface than one that can be exploited remotely without prior access. However, local vulnerabilities can still be serious if they enable privilege escalation, credential theft, or persistence. I would evaluate required privileges, likelihood of obtaining local access, exploit reliability, and resulting impact. A remotely exploitable vulnerability with no authentication requirement is usually more urgent, all else being equal.

9. How would you evaluate the security risks of unconnected or unnecessary services running on a Linux system?

Answer: I would inventory unnecessary services, identify the interfaces on which they listen, check whether they are reachable from untrusted networks, and verify their versions and configurations. I would assess known vulnerabilities, weak authentication, excessive privileges, and unnecessary exposure. Removing unused services and restricting required services with host firewalls reduces the attack surface.

10. Why are rhosts and hosts.equiv considered security risks in Linux? How would you evaluate their impact on system security?

Answer: rhosts and hosts.equiv can permit trust-based authentication between Unix/Linux systems without requiring strong password-based authentication. If an attacker compromises a trusted host, that trust relationship may be abused. I would check whether these files exist, what hosts and users they trust, and whether the trust is still required. Risk is higher when broad or wildcard trust is configured, especially for privileged accounts.

11. How would you assess whether an NFS configuration exposes sensitive Linux files to unauthorized users?

Answer: I would review NFS exports and determine which directories are shared, which clients are permitted, whether access is read-only or read-write, and whether root access is appropriately restricted. I would also review network segmentation and NFS security controls. Sensitive directories exposed to unauthorized networks or writable by untrusted clients represent a significant risk.

12. A Linux file has incorrect permissions that allow unauthorized modification. How would you evaluate the resulting security risk?

Answer: I would identify who can modify the file, what the file controls, and what could happen if it were changed. If the file is a configuration, script, executable, authentication file, or other security-sensitive resource, unauthorized modification could lead to privilege escalation or code execution. Severity depends on required privileges, accessibility, exploit reliability, and impact. Ownership and permissions should follow least privilege.

13. How would you compare the security impact of weak file permissions with an unpatched Linux vulnerability?

Answer: Weak file permissions are often configuration issues and may be immediately exploitable if a sensitive file is writable by an untrusted user. An unpatched vulnerability may have broader consequences and could sometimes be remotely exploitable. I would compare exploitability, privileges required, exposure, reliability, affected assets, and impact. A writable root-owned script can be critical even without a software vulnerability.

14. How would you evaluate whether a buffer overflow vulnerability in a Linux application is practically exploitable?

Answer: I would first confirm the vulnerability using safe, controlled testing and determine whether the application is affected by the relevant memory-safety condition. I would assess whether it can be triggered reliably and whether protections such as ASLR, DEP/NX, stack canaries, sandboxing, and compiler defenses are enabled. Practical exploitability depends on both the vulnerability and the surrounding environment.

15. Which factors would you consider before selecting an exploitation technique for a Linux vulnerability?

Answer: I would consider the vulnerability type, affected software version, operating system, required privileges, authentication requirements, network reachability, exploit reliability, security controls, and testing objective. The technique should be appropriate to the authorized scope and minimize disruption. Controlled proof-of-concept validation is preferable to destructive exploitation.

16. How would you evaluate the security of a messaging application that stores user credentials or messages insecurely?

Answer: I would examine how credentials and messages are stored and transmitted, whether passwords are securely hashed, whether sensitive data is encrypted at rest and in transit, and whether logs or backups expose it. I would also review authentication, session management, local storage, access controls, and API security. Severity increases when credentials or private messages can be recovered by unauthorized users.

17. A web application is vulnerable to SQL injection. How would you evaluate the severity of this vulnerability and its possible consequences?

Answer: I would confirm that user-controlled input reaches a database query without adequate parameterization or safe query construction. I would assess affected data, authentication boundaries, database privileges, reachable functionality, and whether the issue could cause data disclosure, modification, account takeover, or broader compromise. Severity should reflect both exploitability and business impact.

18. How would you determine whether a web application vulnerability represents a critical security risk or a low-risk finding?

Answer: I would consider exploitability, required privileges, attack complexity, user interaction, scope, confidentiality, integrity, availability, and the sensitivity of affected systems or data. Internet exposure and reliable unauthenticated exploitation increase severity. A vulnerability with limited impact and significant prerequisites may be low risk, while a remotely exploitable flaw affecting sensitive data may be critical.

19. How would you evaluate the security of a mobile application using a tool such as MobSF?

Answer: Using MobSF, I would review static and dynamic analysis results where authorized. I would examine permissions, exported components, insecure storage, hardcoded secrets, cryptographic practices, network security configuration, API endpoints, WebViews, authentication, and risky dependencies. Important findings should be manually validated to reduce false positives and then prioritized according to exploitability and impact.

20. A mobile application requests unnecessary permissions such as contacts, microphone, and location. How would you evaluate the associated security risk?

Answer: I would determine whether each permission is necessary for documented functionality and whether it is requested appropriately. Excessive permissions increase the potential impact of compromise, misuse, or data leakage. I would assess what sensitive information each permission exposes. Least-privilege permission design and clear user consent reduce risk.

21. How would you evaluate the risk of hardcoded API keys or passwords discovered during mobile application analysis?

Answer: I would determine whether the secret is active, what resources it can access, its privilege level, expiration status, and whether it is embedded in a publicly distributable application. An active high-privilege API key or password can allow unauthorized access to backend services, data, or cloud resources. Exposed credentials should be revoked or rotated and logs reviewed for possible misuse.

22. If the same vulnerability is found in both a web application and a mobile application, how would you compare their security impact?

Answer: I would compare the vulnerability in terms of exposure, reachable functionality, authentication requirements, affected data, user interaction, exploitability, and the role of each platform. A mobile issue may depend on a compromised device or application package, while a web issue may be directly reachable over a network. The vulnerability type alone does not determine severity.

23. How would you select appropriate hacking tools for assessing Windows, Linux, web, and mobile applications?

Answer: I would map each tool to the technology and testing objective. For Windows, service discovery and vulnerability assessment tools are useful; for Linux, network and host configuration assessment tools are appropriate; for web applications, intercepting proxies and web vulnerability scanners can help; and for mobile applications, MobSF and platform-specific analysis tools are useful. Tool selection should consider authorization, accuracy, coverage, safety, and update status.

24. After performing vulnerability exploitation, how would you evaluate whether the exploitation technique actually demonstrates a significant security weakness?

Answer: I would verify that the technique produced a reproducible result, identify the privileges or access gained, and establish what security boundary was crossed. I would avoid unnecessary persistence or destructive actions. Evidence should demonstrate actual impact while preserving system stability. A meaningful finding should connect the technical proof to a realistic business consequence.

25. You have identified vulnerabilities in Windows, Linux, messaging, web, and mobile applications. How would you prioritize them and prepare a professional security report?

Answer: I would consolidate and validate all findings, remove duplicates, and assign severity based on exploitability, impact, exposure, required privileges, and business criticality. Critical and high-risk issues should be addressed first, especially those enabling remote compromise, credential theft, sensitive-data exposure, or privilege escalation. The professional report should include an executive summary, scope and methodology, risk rating, evidence, affected assets, business impact, remediation guidance, and a prioritized remediation plan.